Regras de Negócio para Autenticação

RN-Auth-01 - Mensagem Genérica de Erro de Senha

Descrição: Para evitar ataques de enumeração de usuários (onde um invasor tenta descobrir se um e-mail está cadastrado no banco de dados), o sistema nunca deve especificar se o erro ocorreu no e-mail ou na senha. A mensagem de erro deve ser sempre genérica.

- **Cenário 1: Tentativa de login com senha incorreta**
  - **Dado** que o usuário preenche a tela de login com um e-mail válido e cadastrado
  - **E** insere uma senha incorreta
  - **Quando** ele clica no botão "Entrar" (requisição POST /api/auth/login)
  - **Então** o sistema deve retornar o status HTTP 401 (Unauthorized)
  - **E** o Frontend deve exibir a mensagem de erro genérica: "E-mail ou senha inválidos."
- **Cenário 2: Tentativa de login com e-mail inexistente**
  - **Dado** que o usuário preenche a tela de login com um e-mail não cadastrado na base
  - **Quando** ele clica no botão "Entrar"
  - **Então** o sistema deve simular o tempo de processamento padrão (para evitar timing attacks)
  - **E** retornar a mesma mensagem de erro genérica: "E-mail ou senha inválidos."

RN-Auth-02 - Bloqueio de Conta por Múltiplas Tentativas (Lockout)

Descrição: Para mitigar ataques de força bruta, a conta do usuário deve ser temporariamente bloqueada caso haja múltiplas falhas consecutivas de autenticação.(Nota: O padrão recomendado para esta regra é o bloqueio após 5 tentativas por um período de 15 minutos).

- **Cenário 1: Bloqueio após limite de tentativas excedido**
  - **Dado** que o usuário está na tela de login
  - **E** já falhou na autenticação 4 vezes consecutivas
  - **Quando** ele insere as credenciais incorretas pela 5ª vez
  - **Então** o sistema deve alterar o status da conta para "Bloqueada"
  - **E** retornar a mensagem: "Sua conta foi temporariamente bloqueada por excesso de tentativas. Tente novamente em 15 minutos."
- **Cenário 2: Tentativa de login durante o período de bloqueio**
  - **Dado** que a conta do usuário está no período de bloqueio de 15 minutos
  - **Quando** ele tenta fazer login, mesmo utilizando a senha correta
  - **Então** o sistema deve rejeitar a requisição (HTTP 403 Forbidden)
  - **E** exibir a mensagem: "Conta bloqueada. Aguarde o fim do período de 15 minutos para tentar novamente."

RN-Auth-03 - Expiração e Comportamento de Sessão

Descrição: A sessão do usuário no Frontend é orientada pela validade do token JWT. Se o token expirar e não houver um mecanismo de Refresh Token válido, o usuário deve ser deslogado de forma segura, garantindo que nenhum dado sensível do processo (como laudos) fique exposto na tela.

- **Cenário 1: Sessão expirada durante a navegação**
  - **Dado** que o usuário está logado e navegando na aba "Receita Federal"
  - **E** o seu Access Token JWT expira
  - **Quando** o Frontend tenta realizar uma requisição para a API (ex: salvar rascunho) e recebe um HTTP 401
  - **E** não há um Refresh Token válido disponível
  - **Então** o Frontend deve limpar todos os dados do usuário do armazenamento local (LocalStorage/SessionStorage)
  - **E** redirecionar o usuário imediatamente para a tela de /login
  - **E** exibir um Toast informando: "Sua sessão expirou por inatividade. Faça login novamente para continuar."
- **Cenário 2: Retorno à aplicação com sessão totalmente expirada (Refresh Token vencido)**
  - **Dado** que o usuário acessa a plataforma após 8 dias desde o seu último acesso
  - **E** tanto o seu Access Token (60 minutos) quanto o seu Refresh Token (7 dias) já estão expirados no armazenamento local do navegador
  - **Quando** a aplicação (Frontend) é inicializada e tenta restaurar a sessão do usuário
  - **Então** o sistema não deve tentar realizar a renovação silenciosa do token na API
  - **E** deve limpar imediatamente quaisquer dados residuais do usuário do armazenamento (LocalStorage/SessionStorage)
  - **E** manter o usuário na tela de /login, exigindo a inserção das credenciais para uma nova autenticação completa.

RN-Auth-04 - Tempo de Vida e Revogação do Token (Baseado no .env)

Descrição: Conforme configurado no seu ambiente (.env), o Access Token JWT possui uma vida útil de 60 minutos (JWT_EXPIRES_IN_MINUTES=60) e o Refresh Token dura 7 dias (REFRESH_TOKEN_EXPIRES_IN_DAYS=7). Apenas um encerramento explícito (Logout) ou a exclusão da conta anulam imediatamente a validade do token.

- **Cenário 1: Renovação de sessão silenciosa (Refresh Token)**
  - **Dado** que o Access Token (60 minutos) do usuário expirou
  - **E** ele ainda possui um Refresh Token válido (dentro do prazo de 7 dias)
  - **Quando** o Frontend intercepta o erro 401 da API
  - **Então** o Frontend deve solicitar silenciosamente um novo Access Token utilizando o Refresh Token
  - **E** reprocessar a requisição original sem interromper a navegação do usuário.
- **Cenário 2: Revogação explícita de Token (Logout)**
  - **Dado** que o usuário possui um token JWT com 40 minutos de validade restantes
  - **Quando** ele clica no botão "Sair" (requisição POST /api/auth/logout)
  - **Então** o sistema deve adicionar o identificador do token (jti) à tabela de token_revogado
  - **E** qualquer tentativa posterior de usar esse mesmo token JWT deverá retornar acesso negado (HTTP 401), mesmo que ele ainda esteja dentro do prazo de 60 minutos.